

Bài 4: Nguyên cơ bảo mật trên hệ thống (System Hacking)

Lý thuyết: $\Rightarrow$ 5 bước:

- 1) Crack pass: bẻ khóa $\rightarrow$ vào để tk user
- 2) Leo thang đặc quyền: tìm key đồng $\rightarrow$ lên Admin
- 3) Chạy app: gắn camera lên (keylogger, spyware, backdoor) $\rightarrow$ quay lại lúc nào cũng được
- 4) Ẩn file: giấu đồ nghề trong tường (NTFS ADS, Steganography)
- 5) Xóa dấu vết: xóa camera an ninh $\rightarrow$ xóa/sửa file log

1) Crack pass: - Độ mạnh MK = (số loại ký tự có thể dùng)^{độ dài}. Chỉ số $\rightarrow 10^n$ yếu nhất. Chỉ chữ thường $\rightarrow 26^n$. 2 loại $\rightarrow \sim 52-70^n$. 3-4 loại $\rightarrow$ 30ⁿ mạnh nhất, cũng độ dài $\rightarrow$ nhưn local, ký tự hỗn $\rightarrow$ mạnh hơn. - 5 KT crack: a) Từ điển: thử ds pass có sẵn. b) Vết can: thử mọi tổ hợp, chắc ra những rất lâu. c) Lai (Hybrid): từ điển + thêm số/ký tự (vd: motkhan134). d) Kẽ + hợp (Syllable): từ điển thực, ra thì chuyển sang vết can. e) Dựa trên luật: biết rule đặt MK của tổ chức $\rightarrow$ nhanh nhất (vd: MK mặc định = năm nhập học + mã khóa + STT)

- 4 nhóm tấn công MK. a) Online thụ động: chỉ nghe lén, 0 dùng vào: sniffing, MITM, replay. Online chủ động: tương tác trực tiếp: đoán MK, cài trojan/keylogger, hash injection.

c) offline lấy hash về máy mình phá, 0 cần kết nối đích: Rainbow table. d) Phi điển từ 0 cần máy: nhìn trộm qua vai, lừa đảo, lục thùng rác. - File SAM (C:\Windows\System32\config\SAM) = nơi Window lưu MK đã bấm. Win đang chạy thì 0 xóa/copy được $\rightarrow$ phải boot bằng HĐH khác. - file đã xóa vẫn khôi phục được (kể cả shift + Delete): HĐH chỉ xóa dòng trong mục lục, để vẫn nằm trên đĩa. - Công cụ crack: L0phtCrack, Ophcrack, Cain & Abel, John the Ripper, Rainbow Crack. - Trộm MK = USB chép tool crack + file autorun.inf gọi file.bat chạy tự động. - Bảo vệ MK: ≥ 8 ký tự đủ loại, 0 dùng chung, chữ định kỳ, giám sát log, 0 dùng từ điển/thông tin cá nhân. Syskey (mã hóa SAM) đã bị Win 10/11 gỡ vì bị lỗi dùng tổng tiến.

2) Leo thang đặc quyền - Sticky Keys: - Nhấn Shift 5 lần ở màn hình login $\rightarrow$ Win chạy file sethc.exe (tạo năng). - Hacker thay sethc.exe = cmd.exe $\rightarrow$ Shift 5 lần mở cmd quyền admin $\rightarrow$ tạo ra user admin mới. - Phòng: ① mã hóa để nhạy cảm (quan trọng nhất). ② 0 dùng tk admin hằng ngày.

3) Chạy app: - Keylogger: ghi phím gõ $\rightarrow$ chống = bàn phím ảo. - Spyware: theo dõi mọi thứ (màn hình, GPS, mic, email, máy in, ...) $\rightarrow$ làm chậm máy, trộm info, giám sát Internet. 4) Ẩn file:

Meo

① Số độ mạnh MK: đếm số loại ký tự thực, rồi mới xét độ dài.

② Keyboard nhận biết KT crack: "ds có sẵn" = từ điển || "mọi tổ hợp" = vết can || "từ + số" = Lai || "từ điển + vết can" = Kẽ + hợp || "biết qui luật" = Dựa + trên luật.

③ Nhận biết nhóm tấn công: có cần máy 0? (không $\Rightarrow$ Phi điển từ) $\rightarrow$ có kết nối đích 0? (không $\rightarrow$ Offline) $\rightarrow$ có tác động 0? (0 $\Rightarrow$ online thụ động; có $\rightarrow$ chủ động)

④ Nhanh nhất là Dựa trên luật, chậm nhất là vết can

⑤ Rainbow Table = Offline ⑥ Nhìn trộm/lục thùng rác - Phi điển từ

① LISTENING = đang mở chờ kết nối; ESTABLISHED = đã kết nối. ② Rủi ro 0 có mức 5, 7, 8 (chỉ có 1, 2, 3, 4, 6, 9). ③ Cổng 445 = chia sẻ (S-M-B); 3389 đk từ xa (RDP). ④ Đề hỏi "dùng tool nào" $\rightarrow$ nhìn dòng từ: gty user/nhóm = lusrmgr || đặt chính sách, khóa TK/tắt Guest = Secpol || xem log = eventvwr || xem công = netstat -ano || Xem tiến trình, bộ nhớ = Process Explorer || Xem wifi = netsh wlan.

⑤ Đề hỏi "chiến lược xử lý rủi ro" $\rightarrow$ Từ khóa: ngừng, 0 làm = Avoid || cài thêm, update, bất = Mitigate || Bảo hiểm, thuê ngoài = Transfer || Rủi ro nhỏ, bỏ qua = Accept

⑥ Tính mức rủi ro: nhân 2 số (impact x Likelihood); 1-2 (thấp) 3-4 (TB) 6-9 (cao)

⑦ DL chưa lưu vẫn nằm trong RAM; Hibernation (0 phải Sleep) mới ghi RAM xuống đĩa.

⑧ WPA2 không tự động an toàn, MK yếu vẫn bị dò.

Đây là phần bổ sung của Bài 8 LAB, 0 phải bài 4 ME0

* Chủ cần phân biệt các loại MĐ + nắm ý chính
 => MĐ = ctr viết với ý đồ xấu: phá đl; đánh cắp; theo dõi; đk từ xa

Bài 5: Mã độc & phân tích Mã độc (MĐ)

Lý thuyết

- Phân loại** (hỏi: Tự lây 0? Cần file chủ 0?) (Loại II Tự lây II Cần file II Nhân ra bằng)
 - 1) Virus II V II V II Bám vào file; tự copy nhiều file
 - 2) Worm II V II x II Tự đi qua mạng; khai thác lỗ hổng
 - 3) Trojan II x II x II Đòi tất p. mềm có ích, thường 1 file
 - 4) Backdoor / RAT II x II x II ĐK máy từ xa
 - 5) Ransomware II tùy II x II Mã hóa đl đòi tiền chuộc
 - 6) Spyware / Keylogger II x II x II theo dõi
 - 7) Adware II x II x II Hiện quảng cáo
 - 8) Rootkit II x II x II Che dấu process, file
 - 9) Bot / Botnet II tùy II x II Máy thành zombie nhận lệnh (DDos, spam)
 - 10) Logic bomb II x II x II "nổ" khi đủ đk
- 5 đặc tính virus**: lây lan + phá hoại + nhỏ gọn + tự ý thích + kế thừa / biến thể
- Mục tiêu Trojan**: trộm info (Keylogger); theo dõi; biến máy thành proxy; biến máy thành zombie botnet (DDos, spam)
- 7 nguồn lây**: Messenger II file đính kèm II usb / ổ ngoài II web + email II chia sẻ file II p. mềm đl II game, Screensaver tải về
- 6 vòng đời**:
 - a) **Xâm nhập**: email phishing, USB, drive-by download, supply chain (gài vào bản update) => phần lớn bắt từ lỗi con người
 - b) **Thực thi**: ng dùng bấm **Enable Macros** (bỏ shell)
 - c) **Duy trì**: Registry Run Key; Scheduled Task; thư mục startup -> mở máy là chạy
 - d) **Lan truyền**: qua SMB, RDP; Pass-the-hash
 - e) **Liên lạc C2**: nhận lệnh từ máy chủ hacker
- Hành động**: trộm đl; ransomware; đòi coin; phá hoại
- netstat -ano** -> 4 cột: giao thức II đ/chủ: cổng cục bộ II đ/chủ: cổng từ xa II status (PID)

	Tĩnh	Động
Có chạy MĐ	Không; chỉ "mô xê" file	Có; trong sandbox
Ưu	An toàn; nhanh	Thấy hành vi thật
Nhược	Bỏ tay khi MĐ bị nén / làm rối (packing)	Có nguy cơ lây; MĐ có thể p/hiển máy ảo và "giả mạo"
- Phân tích MĐ (Tĩnh vs Động)**
 - Tĩnh (mục tiêu)**: hiểu sơ bộ mà @ run. ~ đoán hành vi qua chuỗi & API. Tạo IoC / Churn. Xét tính họ MĐ. **Các bước**: VM cách ly + snapshot -> lấy hash, tra VirusTotal -> xem cấu trúc -> Ktra có bị pack -> rút strings (URL, IP, registry) -> xem API gọi -> Trích IoC -> Kết luận. Công cụ: PEStudio; Strings; VirusTotal; IDA / Ghidra; YARA.
 - Động - môi trường (sandbox)**: cô lập khỏi máy & mạng thật. Khởi phục nhanh = snapshot. Có công cụ giám sát & log. Sandbox: Cuckoo, Any.Run. Máy giả: Host-Only; INetSim. Công cụ: RegShot (chụp registry trước / sau rồi so). Process Monitor / Explorer; Wireshark; TCPview, Autoruns.
 - Nguyên tắc chạy mã độc an toàn**: Chỉ trong VM; ngắt mạng; tắt Shared Folder, clipboard, Kéo thả; Snapshot trước, Rollback sau. @ login acc thật. @ dùng admin trong VM.
 - Phòng chống 3 cấp**:
 - a) Ngăn ngừa: @ mở file / link lạ, @ dùng cracks, keygen, update. MK mạnh + MFA. Sao lưu 3-2-1 (3 bản, 2 thiết bị, 1 bản offline)
 - b) Hệ thống: vá lỗi; tắt Macro Office; bật Defender; @ dùng admin hằng ngày; limit RDP/SMB; bật firewall
 - c) Mạng: firewall; IDS/IPS; lọc DNS; phân vùng mạng.
 - d) 4 cách phát hiện: Chữ ký (nhanh, chính xác @ bắt đc biến thể) II Hành vi (bắt zero-day; dễ báo nhầm) II AI/ML (nhận MĐ mới, cần đl) II Sandbox (thấy hành vi thật, tốn thời gian).
 - e) Khi bị ransomware: cô lập máy khỏi mạng -> copy, ở ứng thực -> xóa MĐ -> restore từ backup sạch; @ với trả tiền.
 - f) 5 công cụ giám sát công: Netstat (có sẵn); Fport (cổng => tiến trình + đg dẫn); TCPView (xanh => mới, đỏ => vừa đóng); CurrPorts, Process Explorer

Meo

- Chỉ Lý thuyết**, @ nắm tổng tình huống.
- Phân loại MĐ**: tìm Key - "gắn vào file" = Virus II "tự lây qua mạng" = Worm II "Giả làm p. mềm hữu ích" = Trojan II "đòi tiền" = Ransomware II "Che giấu" = Rootkit II "G. cáo" = Adware II "ĐK kích hoạt" = Logic bomb.
- Tĩnh hay động**: @ có chữ "p chạy", hash, strings, PEStudio -> Tĩnh; còn lại -> Động.
- Phát hiện** = chữ ký @ bắt đc zero-day / biến thể -> cần phát hiện theo hành vi.
- 3 loại chính**: Virus - Worm - Trojan.
- Regshot** = chụp ảnh registry trước / sau rồi so.

Note: 1) Wifi = 802.11 2) Cắm dây RJ45 = 802.3 3) dây là Bảo mật (BM) 4) Tập trung 3 khái niệm: Chuẩn (tốc độ, tần số, mã hóa (giấu đi) WEP/AES chứng thực (cứ đc vào)

2) Kiểu MKD: mô tả mạng có dây // Nhiều AP // LAN-to-LAN // 3G Hotspot

Lý thuyết

gđ, quán //

Bài 6: Bảo mật mạng dây

- ① Chuẩn 802.11: 1) Chuẩn a - Năm 1999 - Tốc độ 54Mbps - Tần số 5GHz 2) Ch. b - 1999 - 11Mbps - 2.4GHz 3) Ch. g - 2003 - 54Mbps - 2.4GHz 4) Ch. n - Wifi 4 - 2009 - 600Mbps - 2.4 + 5GHz 5) Ch. ac = Wifi 5 - 2014 - 6.9Gbps - 5. MU-MIMO 6) Ch. ax = Wifi 6 - 2019 - 9.6Gbps - 2.4 + 5GHz (thêm 6GHz) 7) Ch. be = Wifi 7 - 2024 - 46Gbps - 2.4 + 5 + 6GHz 8) Ch. ad/ay - 7/20Gbps - 60GHz
- ⇒ Thêm 802.11i = ch. cải tiến M Hwa (nên WPA2). 802.16 = mạng di động MAN/WiMAX. 10m, 1-3Mbps
- ② SSID (tên mạng) → 8 đặc đ: 1) tốc độ 32 ký tự 2) p. biệt hóa thường 3) Broadcast (phát công khai) / Hidden 4) 0 thực tế ảnh hưởng BM 5) 1 AP phát nhiều SSID (và nhiều AP cùng 1 SSID) 6) đổi SSID default (TP-Link 1834) 7) Chỉ có h/v lực truy cập phủ sóng 8) Doanh nghiệp phát nhiều SSID ≠ mức BM (UIT/UIT Public)
- ③ 3 kiểu CT (thầy chốt) 1) Kiểu // cách vào // dùng ở 2) Open System // Biết SSID là vào, 0 mk // công cộng 2) Shared Key // AP gửi chuỗi thách thức → máy mã hóa = key chung gửi lại → đúng thì cho vào (dùng WEP) 3) RADIUS (802.1X, Enterprise) // AP chuyển info về server RADIUS → trả CSDL → cho 0. Tăng ng 1 TK // thường, doanh nghiệp
- | Công nghệ | Mã hóa bên tổng | An toàn |
|-----------------|-----------------|-------------------|
| WEP | RC4, 128 bit | Vài phút là CRACK |
| TKIP/WPA | RC4 + MIC | Lỗi thời |
| WPA2-PSK | AES-CCMP | gia đình |
| WPA2-Enterprise | AES-CCMP + EAP | Doanh nghiệp |
| WPA3 | SAE + AES-GCMP | Mạnh nhất |
- ④ Bùng mã hóa - từ yếu → mạnh:
- ⑤ Mối đe dọa - 3 nhóm: 1) Vượt kiểm soát + xuy cập Wan đường (lưu xe đồ Wifi + GPS) 2) Rogue AP (AP lạ cắm vào mạng tổ chức) 3) Client Mis-association (AP bên ngoài du NV) 4) Unauthorized Association (mã độc soft AP) 5) Ad Hoc 6) AP Misconfiguration (đổi SSID/pw default, quên bật mã hóa) 7) MAC spoofing 8) Promiscuous Client (phát sóng cực mạnh) 9) Đánh lừa: HoneySpot = fake wifi mang tên thương hiệu quen
- ⑥ Giảm chặn (DoS) 1) Gửi gói de-authenticate 2) Jamming 3) Thiết bị gây nhiễu (dùng điện là phạm luật ở VN) 4) Chuối hàu giả Rouge AP / nạn nhân chờ vì sóng mạnh
- ⑦ 5 bước tấn công + công cụ: 1) Khám phá mạng - inSSIDer, NetSpot, NetStumbler 2) Về map GPS - WiGLE, Skyhook 3) Phân tích traffic - Wireshark, Omnicast 4) Tấn công - Aircrack-ng 5) Crack pw - Aircrack-ng
- ⇒ Bỏ Aircrack-ng: airmmon-ng = bật monitor mode // airodump-ng = dò SSID, bắt gói // aircrack-ng = gửi de-auth ep máy connect lại để bắt tay // aircrack-ng = crack khóa
- ⇒ Crack chỉ an khi pw đơn giản VÀ mã hóa yếu (WEP)
- ⑧ 4 cum phòng chống: 1) Cấu hình AP: đổi SSID + pw router mặc định, Tắt quản trị từ xa/qa wifi. Bật mã hóa, đổi passphrase định kỳ. Cập nhật firmware. Tắt Wifi khi 0 dùng. 2) Vùng phủ sóng: giảm công suất phát. 0 lấy SSID/tên cty làm pw. Tưởng lừa gửi AP và LAN. VPN/IPSEC. 3) Chứng thực: dùng WPA2 Enterprise + RADIUS. 4) Phát hiện Rogue AP: quét RF (cắm bên). Quét AP có sẵn. Dò từ mạng có dây (SNMP, CDP) → chặn: khóa cổng switch, rút thiết bị. Giám sát: Wireless IDS.

VD tình huống

Cổng switch

Mẹo

- Nhà mạng lắp sẵn router tên "TP-Link_A1Bc", pw dán dưới đây → Lỗi AP Misconfiguration
- Ở sb thấy "Starbucks-Free-Wifi", sóng mạnh → HoneySpot → 0 nỡ, nếu cần dùng 4G hoặc VPN
- Nhỏ từ cắm router giăng vào ổ mạng cty → Rouge AP → phiên = quét RF/dò từ mạng có dây, khóa
- Đang dùng wifi thì liên tục rớt mạng, hồi từ nỡ lại. ⇒ Có thể bị gửi de-authenticate (DoS)
- Quan cf chỉ cần KtH vào nhanh ⇒ Open System / Captive Portal; Nhà riêng ⇒ WPA2/WPA3 Personal
- ① Hời "Kiến CT" → chỉ chọn trong Open / Shared Key / RADIUS. (+ MAC, Captive Portal, EAP, WPS).
- Nên thay WEP/AES, TKIP trả đáp án → đó là mã hóa ⇒ Loại.
- ② Keyword nhận diện đe dọa: "lưu xe đồ" = Wan đường // "cắm AP lạ vào mạng cty" = Rouge AP // "tên thương hiệu quen" = HoneySpot // "Ngắt kết nối hàng loạt" = DoS de-auth // "Đổi MAC đi qua lại" = MAC spoofing // "Đổi cấu hình mặc định" = AP Misconfiguration.
- ③ Tool Aircrack-ng → đọc suffix: airmmon = monitor mode // airodump = dump (dò, bắt) // aircrack = crack
- ④ Airplay = replay gói (de-auth) // aircrack = crack
- ⑤ An SSID & loc MAC ⇒ 0 phải biến pháp BM đủ mạnh (dò đc). ⑥ Shared Key (WEP) ⇒ yếu, RADIUS mạnh
- ⑦ WEP 64 bit thực chỉ 40 bit, 128 bit thực chỉ 104 bit (đừng chọn 64/128).
- ⑧ Độ an toàn: WEP < WPA < WPA2 < WPA3 ⇒ Số càng to càng an toàn. AES mới an toàn, RC4 là yếu

2) Đề thường ra tình huống: Cty Hybrid; bối cảnh (qan cđ; thư viện,...) nhưng dấu hiệu **hết** ⇒ học bằng dấu hiệu ở cuối tháng

Bài 8: LAB + Tình huống (thuộc 10 tình huống)

Bảng tra (thực lòng)

Nhóm	Giá trị
Event ID	4624 (login thành công); 4625 (login thất bại); 4740 (acc bị khóa); 4720 (tạo acc); 4732 (thêm vào nhóm)
Cổng	22 SSH; 80 HTTP; 443 HTTPS; 445 SMB (WannaCry lây ga); 3389 RDP (đk từ xa)
3 file.msc	lusrmgmt.msc = user/nhóm; secpol.msc = chính sách (lockout, Guest, đk dck MK; eventvwr = xem log)
Lệnh	Để làm gì
winvet	Windows version
whoami	đang dùng TK nào
net user	ds TK → TK là Guest bắt = xui xỏ
net user guest /active:no	Tắt Guest (cmd quyền Admin)
net user <tên>	Pw never expires = Yes → nh
Lệnh	Để làm gì
systeminfo	OS, RAM, ngày cài, bản vá (hotfix)
ipconfig	Địa chỉ IPv4
netstat -ano	LISTENING (mở); Established (kết nối) PID
net share	ADMIN\$, C\$, bth; public folder share = nh
firewall	3 profile Domain/Private/Public đều phải ON

LAB 2: Dò MK chủ động (online)

- Tạo TK = lusrmgmt.msc → secpol.msc → Account policies → Account Lockout policy: threshold = 3; duration = 15p; reset counter = 15p → Gõ sai → xem eventvwr.msc → Windows Logs → Security → Log 4625, 4740

- KQ: ngưỡng 3 ⇒ 3 SK 4625 rồi 1 SK 4740. Đã bị khóa rồi thì có gõ đúng MK cũng 0 vào đc.

- Online (thử thử lên máy): chậm, dễ bị log, bị khóa // Offline (lấy file bấm về phn): nhanh, 0 log

- Threshold quá thấp ⇒ ng thất bị khóa oan; kẻ xấu có gõ sai để khóa TK ng khác (là 1 dạng DoS).

Threshold quá cao ⇒ Hacker đc thử nhiều lần. Tóm lại: 5-10 + MFA

Lab 3: Info RAM

- Tool: Task Manager (Processes, Details xem PID) // tasklist // PowerShell Get-Process | Sort-Object -Descending -Property PrivateBytes, WorkingSet // chuột phải Process Explorer (Properties → Memory: Private Bytes, Working Set, tab Strings) // chuột phải

→ Create dump file (cmd) // nâng cao: volatility

- Gõ PW vào Notepad & lưu → vẫn tìm thấy trong RAM: app phải giữ DL trong RAM để xử lý; đóng app thì vưng nhớ chỉ đc đánh dấu thôi, 0 xóa trắng. Hacker lấy đc từ RAM: PW, khóa đăng nh, token/cookie phiên (vượt cả MFA); nội dung đang soạn.

- Sleep = RAM có điện // Hibernation = ghi RAM xuống ổ cứng → lỡ nếu ổ ổ mã hóa.

- Giảm nh: khóa màn hình; tắt hẳn máy khi mang ra ngoài. Mã hóa toàn ổ, xóa file dump sau khi v

Lab 4: Wifi và phone

Lệnh/thao tác | Để làm gì

nwss network mode = bssid | Quét wifi xung quanh: SSID; Authentication; Encryption; Signal

nwss interfaces | Mạng đang nối dùng Cipher gì

nwss drivers | Card có hỗ trợ WPA3 ko

Hotspot phone | WPA2/WPA3, MK > 12 ký tự

Manage known networks → Forget | Xóa wifi public đã lưu (chống evil twin không tên tự nhớ lại)

Phone | khóa màn hình PIN, 6 số + Finger/Face ID; cập nhật OS; quyền app = while using / Ask every time

⇒ Đánh giá: Open = Open toàn; Thấy CCMP = đang dùng AES. // Login trên HTTP → MK đi dạng rõ, mất cookie phiên, bị trang giả / MITM

Lab 5: Gly xui xỏ + Xu thế

- Quy trình: Asset → Mối đe dọa (threat) → Vulnerability → Đánh giá nh → Xử lý nh.

- Rủi ro = Khả năng xảy ra (Likelihood) x Mức ả/hướng (impact) ⇒ 1-2 (thấp) 3-4 (TB) 6-9 (Cao)

- 4 chiến lược: Avoid - Mitigate (giảm, thêm biện pháp) - Transfer - Accept.

- Xu thế: AI (phòng thủ theo hành vi bất thg) ⇒ tấn công = deepfake, phishing cá nhân hóa // IoT (MK default botnet Mirai) // Di động // Dữ liệu cá nhân // Làm việc từ xa (VPN, MFA, Zero Trust = 0 tin mặc định, luôn xác minh).

M&O Bảng dấu hiệu 10 tình huống

Dấu hiệu trong đề	Nghĩa là	Xử lý / Công cụ
Tiến trình lự ~ 2G RAM, nhiều process na ná, khác PID	MĐ giả tên process	Task Manager/tasklist/Process Explorer → xem path, chữ ký số
netstat -ano thấy 445, 3389	SMB (WannaCry lây) + RDP	net user guest /active:no // lusrmgmt // secpol
Guest đang bắt	Cửa vào 2 cạm bẫy	Trà PID, firewall chặn, 0 mở RDP ra Internet
MK dễ: 12345678	Dễ bị từ điển/brute force	Secpol.msc đặt độ dài, độ phức tạp
Firewall tắt ở public	Mất lớp phòng vệ	Bật firewall cả 3 profile
Như 4625 từ 1 IP	Đang bị dò MK	Lọc 4625 ở eventvwr.msc → bật lockout → chặn IP → MFA
4740 liên tục như TK	PW spraying	Tìm máy nguồn, cô lập
TK nv bị thêm vào Administrators	Leo thang đặc quyền	lusrmgmt.msc / Least privilege
Hotspot WPA2 nhưng MK 123456	WPA2 vẫn bị dò MK	MK > 12; ẩn tên WPA3
Dùng wifi public vào hệ thống Cty	Rogue AP/evil twin/MITM nghe lén; HoneySpot	VPN // HTTPS // MFA // Forget mạng // tắt auto connect, dùng 4G